Design continuous authorization and harden the directory



Tim Warner

Principal Author | IT Ops | Pluralsight

TechTrainerTim.com





Checking in with Globomantics



A contractor signs in at eight from a compliant device

Their contract is terminated at eleven

Their token is still valid

Thirty-odd policies, written by three teams, never read together

Authorize continuously instead of at sign-in

One system, four moving parts

Conditional Access is the policy engine that decides at sign-in

Continuous access evaluation lands a revocation in near real time

Risk scoring feeds the engine a signal that changes mid-session

Protected actions demand fresh authorization for posture-changing operations

Microsoft Learn, continuous access evaluation

“User termination or password change/reset: User session revocation is enforced in near real time.”

Citation: Microsoft, “Continuous access evaluation”, learn.microsoft.com/entra/identity/conditional-access/concept-continuous-access-evaluation

Validate a Conditional Access estate against Zero Trust

Validate what the estate enforces, not what it says



Report-only mode

shows what a policy would have done without enforcing it



The Conditional Access optimization agent

recommends fixes you still have to judge

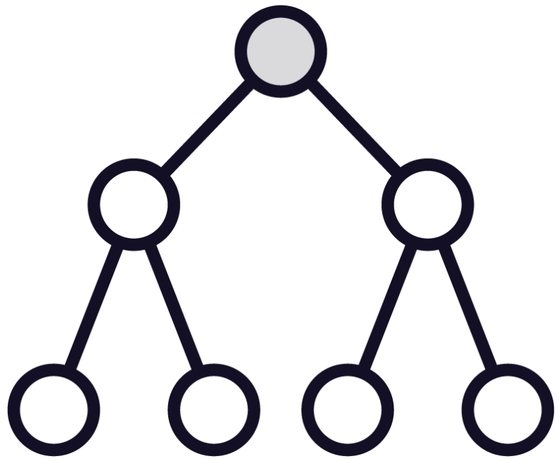


The question most estates fail:

are agent identities covered at all?

Harden Active Directory Domain Services

The forest is a seam your cloud controls can't reach



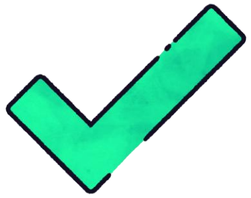
Design against credential theft and lateral movement, the attacks that work there

The inherited forest arrived with an acquisition and still trusts production

The deliverable is a specified requirement, not a configuration step

Design a lifecycle for secrets, keys, and certificates

Secrets, keys, and certificates: do and don't



Do

Store certificates as certificate objects in Azure Key Vault

Decide network access to the vault as its own design question



Don’t

Don't store a certificate as a secret and lose its lifecycle

Don't let private keys live on application servers

Demo: Read an estate you didn't build

Read an existing Conditional Access estate in report-only mode, then triage the secret, key, and certificate inventory for one workload

Relevant SC-100 practice question

End contractor access within minutes

Question

A contractor's access must end within minutes of termination, not at token expiry. Token lifetimes can't change tenant-wide.

A. Reduce sign-in frequency for all users

B. Use continuous access evaluation on supported resources

C. Require a password change at termination

D. Add protected actions to the contractor's roles

End contractor access within minutes

Answer: B

A contractor's access must end within minutes of termination, not at token expiry. Token lifetimes can't change tenant-wide.

A. Reduce sign-in frequency for all users

B. Use continuous access evaluation on supported resources

C. Require a password change at termination

D. Add protected actions to the contractor's roles

Checking out with Globomantics



Design authorization that reacts mid-session, not just at sign-in

Validate what a policy estate enforces, not what it says

Specify forest hardening against credential theft and lateral movement

Give secrets, keys, and certificates a lifecycle, then a store